

Dustin Poston

LetsDefend

Rule: Suspicious Authentication Activity / Possible Brute Force Attack

EventID :	303
Event Time :	Sep, 24, 2024, 08:21 AM
Rule :	SOC325 - Unauthorized Cloud Region Access Attempt Detected
Level :	Security Analyst
Source Address :	134.209.145.73
Destination Address :	52.15.206.21
Username :	test@letsdefend.io
Trigger Reason :	Too many access attempts with the same user were detected in a short period of time from an unauthorized (configured as "unused" or "unsupported") cloud region.
Request URL :	POST /accounts/login HTTP/1.1 403 512
Device Action :	Blocked

High- Level Summary

This alert was generated as a low severity as too many authentication access attempts were detected as a possible brute force attack. The event details reviewed include EventID: 4625, attack type: brute force / password guessing, source IP: 134.209.145.73, destination IP: 52.15.206.21, username: test@defender.io, event time: Sept, 24th, 2024 8:21AM, and alert description: Multiple failed login attempts were detected against a user account from an external source IP within a short period of time. The alert description indicated authentication behavior that appeared abnormal and potentially malicious, requiring investigation to determine whether access was attempted, successfully granted, or perhaps a false positive.

Verdict

Outcome concluded the alert was indeed a True Positive.

Timeline of Activity

First log of attempts started on September 24, 2024 at 7:25AM and lasted until September 24, 2024 8:21AM. No successful logins were made.

Investigation of the Alert and Findings

I reviewed the alert details, including the event identifier, source IP, destination IP, targeted username, timestamp, and alert description. The activity showed suspicious authentication behavior from the source IP toward the destination system involving the identified user account. Firstly, I decided to investigate the source IP to see if the attempts are in fact excessive and who they might be trying to communicate with.

DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT
Columns X Src Address	Operator ↓ contains	Value ↓ 134.209.145.73	134.209.145.73	32162	52.15.206.21
Sep, 24, 2024, 08:11 AM	Firewall	134.209.145.73	61259	52.15.206.21	443
Sep, 24, 2024, 07:39 AM	Firewall	134.209.145.73	52026	52.15.206.21	443
Sep, 24, 2024, 07:25 AM	Firewall	134.209.145.73	63820	52.15.206.21	443
Sep, 24, 2024, 07:34 AM	Firewall	134.209.145.73	43918	52.15.206.21	443
Sep, 24, 2024, 08:04 AM	Firewall	134.209.145.73	55275	52.15.206.21	443
Sep, 24, 2024, 07:52 AM	Firewall	134.209.145.73	60197	52.15.206.21	443
Sep, 24, 2024, 08:14 AM	Firewall	134.209.145.73	13189	52.15.206.21	443
Sep, 24, 2024, 07:43 AM	Firewall	134.209.145.73	16514	52.15.206.21	443
Sep, 24, 2024, 08:11 AM	Firewall	134.209.145.73	32811	52.15.206.21	443

After analyzing the logs for IOCs, I determined that the source IP was only trying to contact one destination IP address using different source ports. After seeing this was happening frequently, I went to endpoint security to check who exactly the potentially malicious IP was trying to get access to.

52.15.206.21

AWS_Services

52.15.206.21

Endpoint Information

Host Information

Hostname: AWS_Services

Domain: LetsDefend

IP Address: 52.15.206.21

Bit Level: 64

OS: Ubuntu 20.04.02

Primary User: Analyst

Client/Server: Server

Last Login: Sep, 24, 2024, 04:00 AM

In the screenshot above you can see it is AWS_services running a Linux Ubuntu. This behavior is not typical, next I looked immediately on AbuseIPDB, and VirusTotal to see if anyone has flagged this IP as malicious.

134.209.145.73

Did you intend to search across the file corpus instead? [Click here](#)

4 / 91

Community Score

4/91 security vendors flagged this IP address as malicious

134.209.145.73 (134.209.0.0/16)

AS 14061 (DigitalOcean, LLC)

Reanalyze

More

Info

Last Analysis Date

13 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Crowdsourced context

HIGH 0

MEDIUM 0

LOW 0

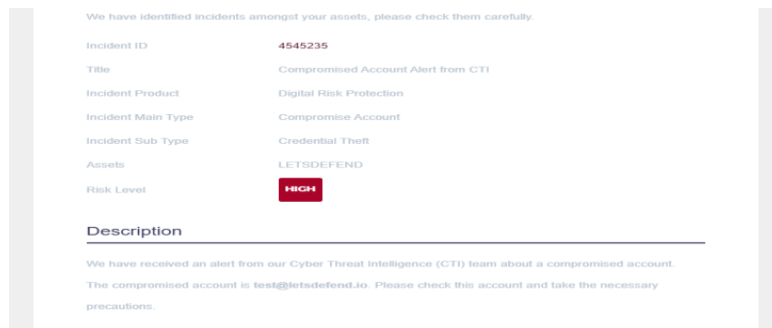
INFO 1

SUCCESS 0

Find more information on CrowdSec CTI - according to source CrowdSec - 2 years ago

Behaviors: SSH Bruteforce

As seen above, this IP has already been flagged and has behaviors of SSH bruteforce attacks. To just cover all bases, I opened email security and see if any other information could be provided as well. At first nothing came up with the IP, however after searching the username we had an email. CTI emailed us days prior letting us know about the malicious username.



I believe I had enough information and certainty to document my findings.

Hypothesis: Brute Force Attack

During the investigation, I mapped the suspicious authentication activity to the MITRE ATT&CK framework. The observed behavior aligned with T1110 (Brute Force) due to multiple authentication attempts originating from a known malicious IP address. After identifying the technique, I reviewed MITRE ATT&CK detection and mitigation guidance to validate the hypothesis and determine whether additional indicators of compromise were present. Threat intelligence sources, including AbuseIPDB and VirusTotal, further supported the assessment by identifying the source IP associated with SSH brute-force activity.

Indicators of Compromise (IOC)

The key indicators identified during this investigation were source IP 134.209.145.73(flagged on AbuseIPDB and VirusTotal for SSH brute-force activity), destination IP 52.15.206.21, and the targeted username jsmith, with the activity mapping to MITRE ATT&CK technique T1110 (Brute Force) at high confidence.

Case Management Summary and Conclusion

I concluded in case management that the alert represented malicious authentication activity consistent with a brute force attack. Based on the investigation, the activity was blocked by existing security controls, and no further remediation was required. The case notes should reflect that the event was reviewed, determined to be malicious, contained successfully, and closed with no additional action needed.

Recommendations

Recommendations include the following: MFA authentication if not already applicable, Lockout policy after certain number of attempts, and geo-location lock if account never logs in from that region.